GOV-03 · Security Incident Response & Escalation Matrix

Who declares an incident, who is told, what the clock is, and what must be preserved before anything is fixed.

Field	Value
Document ID	GOV-03
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	D. Cross-Cutting Governance
Operating tier	Tier 4 — IT Management, which owns security and regulated-data incidents. Detection and containment are Tiers 2 and 3.
Review cycle	Every six months, and after every declared incident.
Precedence	This document takes precedence over every service commitment and capacity state in GOV-06.

1. Purpose

This document names who declares a security incident, who is notified, what the clock is, and what must be preserved before remediation begins. All four are currently implicit, which means they depend on who happens to be on duty.

Most organizations are not short of detection. A managed detection partner may run weekly reviews and raise cases; Defender notifications arrive daily; the tenant has a report button and an external-mail banner. What is missing is the human procedure that turns a detection into a decision.

2. Scope — what is an incident and what is not

Incident	Not an incident (but may become one)
Confirmed or suspected account compromise.	A single failed sign-in from an unfamiliar location.
Credentials entered into a phishing page.	A phishing message reported and purged with no interaction (M365-22).
Malware or ransomware indication on any device.	A blocked download or a quarantined attachment.
Unauthorised access to, or disclosure of, personal or institutional data.	A file shared too widely internally and corrected (M365-11).

Incident	Not an incident (but may become one)
A lost or stolen device holding organization data with no confirmed escrow.	A misplaced device found the same day, still encrypted and escrowed (DEV-16).
Anything with a regulatory clock, such as health, financial or personal-data privacy rules, or state breach notification.	A policy violation with no data exposure (ACC-15, ACC-13).
Confirmed credential sharing or sale.	A third lockout with no evidence of a third party (ACC-05 §5).
Suspected social engineering against the service desk.	A verification correctly declined and logged (ACC-06).

> **When in doubt, declare**
>
> The cost of declaring an incident that turns out to be nothing is a short meeting and a record. The cost of not declaring one that turns out to be something is measured in weeks.
>
> Nobody will be criticised for declaring. The bias in this document is deliberately toward over-declaration, because the reverse bias is what causes the failures that end up in the press.

3. Severity

Sev	Applies when	Declared by	Leadership informed
S1	Organization-wide impact, ransomware, confirmed exposure of personal data, or any regulatory clock running.	The head of IT. If they are unreachable, the most senior IT staff member available declares and the head of IT is informed as soon as possible — a delayed declaration is worse than a wrong one.	Immediately
S2	Confirmed compromise of one or more accounts or devices, contained, with no confirmed data exposure.	Tier 3, head of IT informed within the hour.	Same day
S3	Suspected compromise under investigation; or a pattern across several accounts not yet confirmed.	Tier 3.	In the monthly report unless it escalates
S4	Attempted attack, unsuccessful. Includes social engineering against the desk.	Tier 2, recorded and circulated.	In the monthly report

Severity can rise and frequently does. It is set on what is currently known and revised as more emerges; revising upward is normal and carries no implication that the first assessment was careless.

4. Who does what

Role	In an incident
Incident lead	One named person, appointed at declaration, who holds the decisions and the timeline. Usually Tier 3 for S2–S3 and the head of IT for S1. Not the same person doing the technical work — the lead who is also remediating stops leading.
Technical responders	Tier 2 and Tier 3. Contain, preserve, remediate, and report to the lead. Do not communicate outside IT.
Head of IT / Tier 4	Declares S1, approves all external and community communication, decides on notification obligations, and holds the relationship with leadership.
Tier 1	Fields the resulting contacts using the words the lead supplies. Not left to improvise — the front door will be asked before anybody else.
Managed detection partner	Detection, analysis and advice. Does not declare your incidents and does not communicate to your people (§8).
Leadership	Informed per §3. Decides anything with institutional, legal or reputational consequence beyond IT.

5. The first hour

In order. Appendix A is the card.

1. Establish what is known and what is assumed, and keep them separate. Most bad incident decisions come from acting on an assumption that had hardened into a fact.
2. Declare, with a severity. Appoint the incident lead by name.
3. Start a timeline. One document, appended to as things happen, with times. Reconstructing it afterwards is far harder and considerably less accurate.
4. Preserve, per §6. This comes before remediation wherever the two conflict and the lead decides when they do.
5. Contain: disable sign-in, revoke sessions and tokens, isolate devices, block senders and URLs.
6. Assess scope. What else did this identity or device touch? One compromised account is rarely the whole picture.
7. Notify per §3 and §7. Tell leadership early for S1 — an early call with incomplete information is better received than a complete one that is late.
8. Only then remediate, and record what was done as you go.

6. Preserve before you fix

> **The instinct to fix immediately destroys the evidence needed to know what happened**
> Resetting a password and revoking sessions is the correct containment action and it also removes much of the trail. Wiping a device removes all of it.
> So: where containment and preservation conflict, the incident lead decides, and the default is to preserve first unless the exposure is actively ongoing. An attacker with live access is a reason to contain immediately; an attacker who logged in yesterday is not.

Preserve, before remediating:

- Entra sign-in logs for the affected accounts, exported rather than relied on in place — retention is finite.
- Mailbox audit logs, including rules created, items sent, and items accessed.
- Any inbox rule, delegation, send-as grant or OAuth consent the attacker created — record it before you delete it.
- The phishing message with full headers, where relevant.
- Device state: do not wipe an affected device until the lead agrees, and confirm the BitLocker key is escrowed first (DEV-03 §8).
- The timeline itself, which is the record everything else is read against.

7. Notification

Audience	When and by whom
The affected individual	As soon as containment allows, by the incident lead or Tier 1 using the lead's words. Through a channel independent of the affected account.
Their manager	Where access to institutional data is involved, or under the ACC-05 §5 repeat ladder.
Everyone in the organization	S1, or where people must act — a compromised internal sender, for instance. Head of IT approves. From the established IT notification address, with no links and no requested action beyond contacting the service desk.
Leadership	Per §3.
External parties — regulators, affected data subjects, insurers, counsel	Never by IT. Leadership decides, on advice. IT supplies facts and timelines.
The managed detection partner	Kept current on any case they raised, so the external record matches the internal one (§8).

One thing IT must be clear about internally: whether a notification obligation exists is a legal question, not a technical one. IT's job is to establish the facts quickly and accurately enough that somebody else can answer it.

8. Working with the managed detection partner

The partner raises cases and provides analysis; you decide and act. Three practical points:

- A partner case is not your declaration. Somebody on your side still declares under §3, or explicitly records that no incident is declared and why.
- Close the loop on every case. Where an account was locked for impossible travel and you resolved it, the partner's record should say so — an external case list that diverges from reality is worse than none.
- The partner should be able to find out which MFA system governs which population without asking. If they have to ask, nothing written down answers it. ACC-03 §3 is where that answer lives, and keeping it current is part of this relationship.

9. Closing an incident, and the review

1. The incident lead closes, with the timeline complete and the remediation recorded.
2. Confirm containment held: no further activity from the identity, device or infrastructure involved.
3. Hold a review within ten business days for S1 and S2. Blameless — the question is what the system allowed, not who did what.
4. Produce at most three actions. A review generating twelve produces none.
5. Where an action is a documentation gap, raise it against the relevant SOP under GOV-01 §10. That is how a catalogue like this one grows.
6. Circulate what happened, in specifics, to the department. Specifics teach; policy reminders do not.

10. Service levels

Activity	Commitment
Declare, from the point suspicion is credible	15 minutes. Declaring is cheap.
Appoint an incident lead	At declaration.
Contain a confirmed account compromise	30 minutes from declaration.
Inform the head of IT — S1 or S2	Immediately for S1; within the hour for S2.
Inform leadership — S1	Immediately, with incomplete information if necessary.
Community notice where warranted	Within 4 hours of containment.
Review for S1 and S2	Within 10 business days.

These commitments override every GOV-06 target and capacity state. An incident suspends protected capacity at every tier for its duration.

11. Measurement

- Incidents by severity per quarter, including S4 attempts. A quarter with no S4 recorded means attempts are not being logged, not that none occurred.
- Median time from detection to declaration, and declaration to containment.
- Share of incidents where evidence was preserved before remediation.
- Review actions raised, and how many closed.
- Partner cases raised versus incidents declared — a persistent gap either way is worth understanding.

12. Records

Record	Held in	Retention
Declaration record (Appendix B)	Security record	7 years
Incident timeline	Security record	7 years
Preserved evidence exports	Secured store, access logged	7 years
Notifications sent, with approver	Security record	7 years
Review notes and actions	Security record	7 years
S4 attempts, with what was said	Security + training record	7 years

13. Related documents

ID	Title	Relationship
GOV-06	Service Commitments, Priority & Escalation	Subordinate to this document during an incident.
M365-22	Phishing Reporting & Email Threat Response	Escalates here at confirmed interaction.
ACC-03	MFA Enrollment, Reset & Account Recovery	§10 risky sign-in handling feeds this.
ACC-05	Account Lockout Triage	§5 repeat ladder escalates here.
ACC-06	Identity Verification	S4 attempts against the desk.
ACC-13	Account Suspension for Misuse	Where confirmed sharing goes.
DEV-03	Disk Encryption & BitLocker Keys	Escrow position determines device recoverability.
DEV-16	Lost, Stolen or Compromised Device Response	Device-side of §2.
DEV-14	Endpoint Security Agent & MDR Escalation	The partner relationship in §8.
M365-16	Retention, Legal Hold & eDiscovery	Preservation obligations in §6.

Appendix A — First-hour card

In order. When containment and preservation conflict, the lead decides — default is preserve unless exposure is ongoing.

	Do	Note
1	Separate what is known from what is assumed	Write both down. Most bad calls come from an assumption hardening into a fact.
2	Declare, with a severity. Appoint a lead by name.	When in doubt, declare. Nobody is criticised for it.
3	Start the timeline	One document, times against entries, appended as you go.
4	Preserve — sign-in logs, mailbox audit, rules, delegations, consents	Export. Do not rely on retention.
5	Contain — disable sign-in, revoke sessions AND tokens, isolate devices	A password reset alone does not end a live session.
6	Assess scope — what else did this identity or device touch?	One account is rarely the whole picture.
7	Notify per §3 and §7	S1 → leadership immediately, even with incomplete information.
8	Then remediate. Check for attacker-created MFA methods.	This is the step most often missed — it survives a password reset.

Appendix B — Declaration record

Field	Value
Incident reference	
Declared at (date and time)	
Declared by	
Severity	S1 / S2 / S3 / S4 — revise upward as needed and record when
Incident lead	One named person. Not also doing the technical work.
What is known	
What is assumed	Kept separate, deliberately
Accounts / devices / data involved	
Regulatory clock?	Health, financial or personal-data privacy / state breach notification / none known — if unsure, treat as yes and tell Tier 4
Preservation completed before remediation?	Yes / No / Partial — with the lead's reason

Field	Value
Partner case reference, if any	
Notifications made, and approved by	
Closed at, by	
Review held (S1/S2)	Date, and up to three actions

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.